

KACT Member Data Security Assessment & Website Modernization Decision Log

Official Executive Committee Document

Last Updated Date: 1st March 2026

Prepared by: KACT 2026 Executive Committee

1. Executive Summary

The KACT Executive Committee has completed a comprehensive security and governance review of historical member data management practices and the current modernized website system.

The review confirms that the modern KACT website and AWS-based member management platform provides a significantly stronger security posture, improved governance control, and reduced operational risk compared to prior email-, spreadsheet-, and document-based processes.

The current system already implements strong foundational security controls including encrypted HTTPS communication, role-based access control, centralized database architecture, and structured cloud infrastructure.

2. Purpose of Document

This document serves to:

- Document KACT's website modernization decision
 - Provide a formal security assessment of past vs current systems
 - Highlight validated security strengths of current architecture
 - Identify risks in legacy workflows
 - Record governance and communication decisions
-

3. KACT Website Modernization Initiative

The 2026 Executive Committee initiated the modernization of the KACT website and member management platform to transition from manual, fragmented processes (emails, spreadsheets, Google Docs, and personal storage) into a centralized, secure, cloud-based system using AWS architecture.

3.1 Objectives of Modernization

The platform is designed to:

- Improve website usability and member experience
 - Centralize member registration and management
 - Strengthen security and controlled access
 - Reduce email and spreadsheet dependency
 - Enable role-based access control (RBAC)
 - Improve auditability and accountability
 - Support structured backups and recovery
 - Automate membership renewals and tracking
 - Streamline communication and event management
 - Reduce manual administrative workload
-

4. Security Comparison – Past vs Current

Security Area	Previous Process (Email / Docs)	Current Website System
Data Storage	Spread across inboxes/devices	Centralized AWS database
Access Control	Informal/manual sharing	Role-based access (RBAC)
Revoking Access	Difficult / impossible	Immediate and controlled
Data Duplication	High (multiple copies)	Low (single source)
Auditability	None	Full logging enabled
Device Risk	High (personal devices)	Reduced (controlled access)

Former Member Access	Likely retained copies	Can revoke access centrally
Password Policy	Personal behavior-based	Centrally managed
Backups	Uncontrolled	Structured AWS backups
Monitoring	None	Available via system logs
Security Consistency	Inconsistent	Standardized model

5. Current Security Architecture & Findings (VALIDATED)

5.1 HTTPS / Transport Security

The KACT website uses **encrypted HTTPS communication**:

- Valid SSL/TLS certificate installed
- Let's Encrypt RSA 2048-bit certificate
- SHA256 signature
- Trusted certificate chain
- DNS CAA configuration enabled
- Certificate validity confirmed (expires July 12, 2026)

Security Impact:

- All user communication is encrypted in transit
- Protects against interception and tampering
- Ensures secure browser-to-server connection

Note: HTTPS secures transport but does not prevent application-level or credential-based vulnerabilities.

5.2 System Architecture Security

The current architecture demonstrates modern security design:

- Website frontend separated from payment system
- External payment processing via Zeffy
- AWS-hosted PostgreSQL database
- Cloud-based hosting/CDN architecture (modern web deployment model)
- No storage of credit card or payment credentials

Security Impact:

- Reduces financial data exposure risk
 - Prevents direct handling of sensitive payment data
 - Follows modern separation-of-concerns architecture
-

5.3 AWS Database Security (PostgreSQL)

The database is expected to follow secure cloud architecture:

- Private AWS VPC deployment
- No public internet database exposure
- Application-layer access only
- Role-based admin access control
- Restricted access for authorized executive users

Security Impact:

- Prevents unauthorized external access
 - Enforces network-level isolation
 - Aligns with AWS security best practices
-

5.4 Access Control (RBAC)

- Admin access restricted to authorized roles only
- Strong password policies enforced
- Executive committee-approved access governance
- Principle of least privilege applied

Security Impact:

- Reduces insider threat risk
- Prevents unauthorized data access
- Improves accountability and control

5.5 Backup & Recovery Controls

AWS-based systems provide:

- Automated backups
- Point-in-time recovery
- Snapshot-based restoration
- Defined retention policies

Security Impact:

- Ensures data resilience
 - Enables disaster recovery
 - Protects against accidental loss
-

5.6 Overall Security Position

The current system already provides:

- Encrypted HTTPS communication
- Centralized secure database architecture
- Role-based access control
- External payment processing via Zeffy
- Cloud-based infrastructure security
- Controlled administrative access

Conclusion:

The current system represents a **significant security improvement over legacy processes**.

6. Security Risk Assessment – Previous System (CRITICAL FINDINGS)

6.1 Data Proliferation (Major Risk)

Member data was:

- emailed
- downloaded
- forwarded
- stored across devices

This created uncontrolled duplication across:

- personal inboxes
 - laptops and desktops
 - cloud storage systems
 - backups and archives
-

6.2 Personal Device Exposure

Risks included:

- lack of encryption
 - inconsistent security practices
 - device loss or theft
 - shared device access
-

6.3 Email-Based Security Risks

- Misdelivery and forwarding errors
 - Compromised email accounts
 - Phishing attacks
 - Unauthorized distribution of attachments
-

6.4 Lack of Access Revocation

Once shared:

- access cannot be revoked
- data remains permanently outside control
- former members may retain copies indefinitely

6.5 No Auditability

- No tracking of data access
 - No visibility of sharing or downloads
 - No accountability or monitoring
-

7. Core Security Principle

Modern cybersecurity governance is based on:

- Minimizing exposure
- Reducing duplication
- Controlling access
- Ensuring accountability

Centralized systems provide stronger protection than distributed manual workflows.

8. Residual Risk Acknowledgement

The Committee acknowledges:

- Historical copies may still exist in emails or personal devices
- Legacy distribution cannot be fully reversed
- Residual exposure cannot be eliminated completely

However:

- The modern system prevents future uncontrolled distribution
 - Significantly reduces ongoing exposure risk
-

9. Security Assessment Conclusion

Key Findings:

- Previous system = **high inherent exposure risk**
- Current system = **controlled, centralized, and secure architecture**
- AWS + HTTPS + RBAC = strong foundational security
- External payment processing reduces financial risk exposure

Final Conclusion:

The modern KACT platform aligns with **current cybersecurity best practices** and provides:

- Stronger governance
 - Reduced data exposure
 - Improved access control
 - Better auditability
 - Secure cloud architecture
-

10. Executive Committee Decision

The Executive Committee formally confirms:

- The modern website is the official system of record
 - It replaces email/spreadsheet-based workflows
 - It will continue evolving with enhancements
 - Security improvements (MFA, monitoring, AWS hardening) will be ongoing
-

11. Launch Plan

Planned Launch Date: 24th April 2026

Phase 1 includes:

- Member management system
 - Role-based admin access
 - Event registration system
 - Communication/broadcast system
-

12. Closing Statement

This initiative reflects KACT's commitment to secure, modern, and scalable digital governance, ensuring improved protection of member data and operational efficiency.